SECURITY BRIEFING · THREAT RESPONSE

Phishing: Spot It, Stop It, Report It

Defenders look forsoftwareflaws; adversarieslook for humanshortcuts.

Security Awareness & Incident Readiness · Practical Defense Guide



Phishing emails give themselves away

HEADER & DISPLAY

Sender

Lookalike domains, mismatched display names, and spoofed reply-to addresses designed to slip past rapid visual triage.

PSYCHOLOGY

Content

Manufactured urgency, punitive threats of account lockouts, or unexpected attachments such as fake invoices and remittance notices.

DESTINATION

Links

Hover to inspect the raw destination URL. Shortened links, open redirects, and hidden parameters disguise malicious routing.

METADATA

Authentication

Failed SPF, DKIM alignment breaks, and DMARC soft-fails deliver objective technical telemetry before content is read.

Triage the envelope before trusting the text. The technical headers tell the truth when display names lie.

Fake websites copy everything but the address

Typosquatting & Homoglyphs

Subtle visual swaps like Latin 'rn' imitating 'm' or '0' for 'o' pass skimming eyes. Punycode scripts abuse cross-alphabet homoglyphs.

The Padlock Myth

HTTPS and valid SSL certificates only confirm that connection traffic is encrypted. Attackers obtain automated Let's Encrypt certs in seconds.

Unsolicited Entry Paths

Landing on authentication portals via external links rather than internal managed bookmarks or SSO dashboards guarantees risk exposure.

Credential Harvesters

Modern kits capture credentials and MFA tokens in real time, then immediately redirect the victim to the genuine portal to hide detection.

CRITICAL DISTINCTION

A secure connection to a criminal server is still a connection to a criminal server.

Attackers exploit human reflexes, not software



Authority

the CEO, IT helpdesk or a regulator



Urgency

account locked, payment overdue



Fear and greed

threats and too-good prizes



Trust

pretexting, vishing, smishing and impersonated colleagues

When a message triggers panic, pride, or obedience, pause immediately: emotion is the exploit payload.

Real attacks show how convincing phishing can be

Google & Meta Vendor Impersonation

Between 2013 and 2015, a single operative used forged corporate stamps and fake invoices mimicking hardware manufacturer Quanta Computer to steal over $100M.

The 2020 Twitter Credential Voice Phishing

Attackers phoned support staff impersonating internal IT, directing them to a credential-harvesting clone that bypassed MFA and compromised high-profile accounts.

Common failure thread: a plausible request, an urgent deadline, and skipped out-of-band verification.



Quiz 1: What is wrong with this email?

Which red flags can you spot?

From: IT Helpdesk <it-support@micr0soft-helpdesk.com>

Subject: ACTION REQUIRED: Password expires in 2 hours

Your corporate workstation credentials expire today at 12:00 PM. Retain active directory access and preserve network drives: verify immediately below:

https://login.micr0soft-helpdesk.com/portal/auth-keepalive

Click to keep access.



Answer 1: Three red flags in one message

FLAG 01 · HOMOGLYPH DOMAIN

Typosquatted Host

The sender domain uses a numeral '0' instead of the letter 'o' (micr0soft-helpdesk.com). Microsoft never routes IT notices through third-party domains.

FLAG 02 · ARTIFICIAL TIMING

Forced Urgency

A strict "2 hours" window triggers panic, forcing staff to bypass routine verification out of fear that work files will be abruptly cut off.

FLAG 03 · CREDENTIAL HARVEST

Unverified Auth Link

The link leads to an external unauthenticated form designed to capture SSO passwords and session cookies. Never click; report immediately.

Standard Operating Procedure: Genuine enterprise password resets never arrive with two-hour cutoffs via external links. Route through internal password managers.

Quiz 2: Your CFO texts asking for gift cards

Mid-meeting, a message from an unfamiliar number claims to be the CFO and asks you to buy gift cards urgently. What do you do?

SMS from +1 (555) 019-8422

"Hi, it's Sarah (CFO). I'm locked in a confidential partner review and can't take calls. I need you to purchase 5x $200 Apple gift cards for client incentives right away. Email me the back redemption codes ASAP. Expense it today."



Answer 2: Verify through a known channel

STEP 01 · CONTAIN

Do Not Reply

Never reply, click links, or purchase anything. Any response confirms that your mobile number is active and monitored by a live employee.

STEP 02 · OUT-OF-BAND

Verify on Known Rails

Contact the executive through your corporate directory number, verified Slack, or in person. Never use numbers provided in the incoming message.

STEP 03 · ESCALATE

Report Smishing

Forward message details and sender metadata to the security operations center so the carrier endpoint can be blacklisted company-wide.

ORGANIZATIONAL RULE

No legitimate executive will ever reprimand you for verifying a financial request out-of-band.

Make safe habits automatic

1. **Pause, inspect, then verify out of band.**
2. **Use phishing-resistant MFA and a password manager.**
3. **Keep software patched and navigate via bookmarks.**
4. **Report suspicious messages fast, and never shame clicks.**